

BRAINSTORM NOTES

Cold storage is not a device

A working sketch of how to create Bitcoin keys, back them up so they still exist in twenty years, sign without putting them on a networked computer, and leave a path a family can actually use.

4 October 2026

Sources read for this note: Mr. Hodl, “Cold storage is not a device” (3 Oct 2026); Yeti 2.0 (bowlarbear/yeti-2.0); EntropyLab (OogaBoogaX/entropylab); Liana (Wizardsardine); Nunchuk on-chain inheritance; Unchained and Casa collaborative custody; the July–August 2026 Coldcard entropy incident.

The coins are controlled by keys. The backup preserves access to those keys. The hardware wallet is only the device you currently use to sign with them. Generate carefully. Back up durably. Sign conveniently. And separately: decide who can spend if you stop.

The four jobs

Cold storage is the authority to spend, not a gadget. A robust setup splits that authority into four jobs, then refuses to let any one object, vendor, or person do more than one of them.

Job	What must survive	What is allowed to die
Creation	Entropy you can argue was not guessable	The machine that did the math
Backup	A way to rebuild keys decades later, plus the map of how they combine	Firmware, apps, companies, file formats
Signing	A way to sign one PSBT without putting keys on a networked computer	The signer itself
Inheritance	A path that opens when you stop, and stays shut while you are alive	Your memory, a company, a probate court

A hardware wallet only does the third job well. A seed stamped in steel only does the second. A custodian mostly does the fourth, and does it badly, because they can also do the third.

What the source projects actually are

Mr. Hodl’s frame

People buy a gadget, move coins onto it, and call that cold storage. That skips the part that has to last. Screens break, batteries die, firmware stops, companies disappear. Bitcoin Core’s wallet.dat is the same category of object in a different shape: it can rot, and a future version may open it badly. Unencrypted, the file is the keys.

Nobody serious expects one gadget to boot in 2046. Every serious setup ends at the same instruction: write the secret down and keep it safe. Those words are not an accessory. They are the recovery mechanism. If the device dies and the backup survives, you still have the wallet. If someone gets the seed and nothing stands in front of it, the coins can leave while the device sits untouched in a drawer.

There are three questions, before inheritance is even added. How were the keys created? How is the spend authority backed up? How do you sign without putting that authority on an ordinary online computer? A wallet can take part in all three. It does not have to.

The two tools people actually use do not even give the same backup. A typical hardware wallet gives you the words and not a Core wallet.dat. Bitcoin Core gives you wallet.dat and does not normally give you a BIP39 phrase you can stamp into steel. A seed rebuilds keys. It does not automatically rebuild descriptors, labels, address history, and other wallet state. If the words and the Core wallet come from the same underlying entropy, the split is easier to reason about: steel is the durable human backup, a watch-only wallet.dat can live near the computer you use, and a spendable wallet.dat is a real backup that must be encrypted and kept offline. The signer can be replaced. The recovery information cannot.

Steel does not need firmware, a USB standard, a vendor, or an app store. It has its own problems. Someone can find it, photograph it, or store it badly. A passphrase can be forgotten. A multisig can become unrecoverable if the metadata is lost. Steel is a backup medium. It is not a signing environment.

Yeti 2.0

Yeti 2.0 (github.com/bowlarbear/yeti-2.0) is a written procedure, not an application. Two dedicated computers. Bitcoin Core only, checked against Guix attestations. The signer is an amnesic Ubuntu live session, rebuilt every time, with keys not left at rest. The vault is a 3-of-7 P2WSH multisig. Seven different keys are generated on the offline machine. Each key's wallet material is burned to its own archival disc along with the watch-only descriptor and a README. Any 3 discs can spend. Up to 4 can be lost. The guide's own comfort zone is roughly \$10k to \$5M. Above that they want more machines and sharding.

They explicitly reject several things the rest of the industry treats as normal:

- **Hardware wallets.** Vendor firmware is a supply-chain and review problem. They prefer generic machines plus the most-reviewed Bitcoin software.
- **BIP39 seed phrases.** Bitcoin Core does not speak them. Backups are descriptor wallets and WIF material on optical media, plus instructions, so a future reader needs Core and a disc drive, not the GitHub guide.
- **Encrypted discs.** Encryption recreates a passphrase-management problem. They leave it out of scope.
- **Decaying timelocks.** Someone has to notice the timer. They consider that an operational burden and a way to weaken the vault by accident.
- **Multi-vendor multisig as a security proof.** Several opaque RNGs, plus a coordinator and extra libraries, can be a larger attack surface than one reviewed implementation. Their sharp claim: one inspected Core box is preferable to several vendor RNGs.

The cost of that bet is concentrated. If the single offline machine is lying during key generation, all seven keys are born compromised together. Theft of one or two discs does not spend; it does reveal the watch-only descriptor, which is a balance oracle. Theft of three discs starts a race against the remaining discs. Geographic distribution is the access control. There is no script-level inheritance. An heir who can gather three discs can spend, whether or not you are alive.

Two practical weaknesses sit outside their threat model. The air gap is largely a software setting unless the wireless hardware is physically removed. And the PSBT crosses on USB, which is a classic bridge. Optical media is also a format bet: the reply under Hodl's post, from someone who lived through 8-inch floppies, CDs, DVDs, USB-A, and USB-C-only laptops, is the right objection. A disc that outlasts every drive that can read it is not a backup.

EntropyLab

EntropyLab (github.com/OogaBoogaX/entropylab), from the Ooga Booga group Hodl is part of, is a single HTML file. It does not generate entropy, it does not sign, and it does not broadcast. You bring dice, cards, coins, hex, an existing seed, or a private key. Moved to a machine that is actually offline, and opened only after the file's hash is checked, it turns that material into BIP39 words, xpubs, descriptors, addresses, a watch-only Bitcoin Core wallet.dat, and optionally a spending wallet.dat, all from the same root. It can also build a watch-only multisig from xpubs alone, print a policy sheet, and inspect a PSBT, including animated `ur:crypto-psbt` QR codes.

That is the hole Hodl is pointing at. A hardware wallet gives you words and no Core wallet. Core gives you a wallet file and no words. EntropyLab makes those two views of one root, and it refuses to invent the randomness for you. The quality of the randomness remains your problem, which is the correct place for that problem to sit. Verify the HTML file (published SHA256, signer keys, and an OpenTimestamps proof). A malicious copy can display one seed and save another. After derivation, a second independent codebase must compute the same first address before any coin moves.

Hardware wallets, after the Coldcard failure

From firmware shipped in March 2021 through late July 2026, Coldcard's seed path could silently use a software PRNG (Yasmarang) instead of the hardware RNG it was supposed to mix in. Effective entropy collapsed to roughly the 22–72 bit range depending on model, against a promise of 128 bits or more. Between 30 July and early August 2026, attackers swept on the order of 1,800 BTC from thousands of single-signature addresses. Updating firmware does not repair a seed that was already born weak. Signing itself was not the leak; nonces on those devices were deterministic. The seeds were guessable.

Multisig contained the damage. A weak key that is only one share of a quorum cannot spend alone. The edge case is a quorum that already contains two weak keys from the same bug: the moment a spend reveals the script, an attacker who can grind both seeds can race you. No multisig wallet was drained in the public sweep. That is evidence for quorums. It is not evidence that any particular brand is a safe place to invent entropy.

A hardware wallet remains a good signer. It is a bad place to store the only copy of a key, and it is a bad source of randomness unless you add entropy yourself (dice rolls the device mixes in, or a seed created elsewhere and imported). Stateless QR signers — SeedSigner, Krux, Jade in stateless mode — match the “signer is disposable” rule better than a device that stores the seed for years. Coldcard is a poor choice for new key generation after this incident. Diversity of manufacturers still helps against a firmware backdoor. It does not replace user-supplied entropy.

Collaborative custody and Liana

Unchained and Casa are the familiar 2-of-3: you hold two keys, the company holds one, and the company cannot spend alone. You can leave without them. They are useful as a recovery desk, an inheritance concierge, and sometimes a lending counterparty. They are not the long-term object. Onboarding is KYC. They learn your xpubs. An inheritance plan that lives only in their policy dies with the company, or changes when their terms do.

Nunchuk sits in between. The assisted wallet uses a platform key that cannot spend alone. Their stronger inheritance design is on-chain: Miniscript plus a timelock, so that after the delay the quorum decays and a beneficiary can claim with an inheritance key plus the BSMS wallet configuration, even if Nunchuk is gone. The BSMS file is the map. Their off-chain “flexible” plan is easier to edit — dates, heirs, and phased percentages can change without moving coins — and weaker, because the date is enforced by their co-signing policy rather than by the Bitcoin network.

Liana (Wizardsardine) is the cleanest open tool for the fourth job. One path spends now. One or more recovery paths spend only after the coins have been still for a relative timelock. A practical family shape is: the owner can always spend; a spouse together with another family key can spend after a year of inactivity; a further recovery key can spend later still. Consensus enforces the delay. Nobody can open the recovery path early. The descriptor is as load-bearing as the seeds. You refresh the timer by spending the coins to yourself. If you forget, the recovery path opens while you are alive. That is the trade.

The disagreement worth keeping

Yeti is right that “three brands” is not a security proof. A coordinator bug, a shared library, or two devices from the same broken RNG in one quorum can still burn you. The Coldcard sweep did not empty multisig wallets, but a 2-of-3 with two affected Coldcards becomes a race as soon as the script is revealed.

The multi-vendor argument is right that one generation ceremony is a single point of birth. Seven keys from one random-number generator, on one afternoon, on one disk image, share one failure. A Core bug in key generation would be a serious bug in the most reviewed Bitcoin software. It would also be a bug that hits every key in that ceremony at once.

The reconciliation is not to pick a school. Stop letting any device invent the entropy. Stop generating every key in one sitting on one image.

Dice, coins, or cards are the entropy. EntropyLab, offline and hash-checked, is only a calculator. A second, independent implementation must derive the same first address before a coin is sent. Each key gets its own ceremony, its own boot, its own dice. Vendor RNG quality then stops mattering. That is the only reliable lesson from the Coldcard bug. Adding dice is cheap. It makes Yeti’s “trust Core’s CSPRNG” bet unnecessary without adopting a pile of vendor firmware.

A setup that takes the strong part of each

Use two piles, not one vault. Theft-resistance and inheritance-resistance want opposite shapes. Forcing one script to do both is how plans become unspendable.

Deep vault: most of the coins, no timelock

- **Quorum.** 2-of-3 if a normal family has to be able to operate it. 3-of-5 if the amount is large enough that losing one site must not matter. Yeti’s 3-of-7 is the loss-extreme. It is a poor inheritance experience, and it is more discs than most executors will assemble correctly.
- **Distinct keys.** These are not copies of one seed. Each key is its own dice ceremony.
- **Script.** Native segwit `wsh(sortedmulti(...))`, or taproot with the multisig on a script leaf. Taproot hides the policy until the first spend. Write the full descriptor down anyway. After the first spend, the policy is public.
- **Who can spend today.** You hold a spending quorum without any heir and without any company. A spouse key in the live quorum means they can sign with you today, and can also collude with whoever holds another live key. Decide that on purpose. Do not drift into it.
- **Geography.** Home, a second country, and a third site that is not either house. A fire, a divorce, or a burglary must not collect a quorum. Two copies of key A, stored carefully, are still only key A. Do not “back up” your way into a spendable set by keeping two different keys in one safe.
- **Signers.** No Coldcard for new key generation. Jade in stateless mode, SeedSigner, or Krux are replaceable QR signers. A BitBox02-class device is a reasonable second manufacturer if you want a secure element, but it should load a dice seed, not invent one.

- **Legal separation.** Do not put business or mining coins, trust property, and a personal stack under one descriptor. Legal ownership should match who can sign. A trust-owned vault that one person can empty alone will not look like trust property when someone asks.

Family vault: smaller, and this one is allowed to decay

A taproot or Miniscript policy in the Liana shape:

- **Leaf 1, no delay.** 2-of-3 of your own keys (home, second site, spare). You can always move this pile without asking anyone.
- **Leaf 2, after about 18 to 24 months of stillness.** 2-of-3 among a spouse, a future adult heir, and the trustee. A child should not hold a key that spends today.
- **Optional leaf 3, later still.** Spouse alone, or the trustee plus one heir, if you want a deadlock breaker when people cannot be found.

Relative timelocks (OP_CSV / BIP68) fit the sentence “if these coins sit still, something is wrong.” The timer starts when the UTXO confirms, and it resets when you spend the coins to yourself. Absolute dates (OP_CLTV / BIP65) are easier for an heir to read off a calendar and more dangerous, because they open on that date even if you are actively spending from other wallets. Prefer CSV. Put the reminder further out than one missed year.

Yeti is right that a decaying timer on the main stack is a chore you will fail. So decay only this pile, and make the delay long. Missing the heartbeat does not delete the coins and does not give them to a stranger. It degrades toward the family path. Once a year, consolidate the family vault to itself. Leave the deep vault alone.

The trustee key is collaborative custody without a Bitcoin company and without KYC on the coins. A family trust already knows how to hold an envelope and how to require a death certificate or an incapacity finding. Time-lock that key so a court order plus one stolen family key is not an instant sweep. If you hear about the order, you move the coins with your own quorum before the delay matures.

If people and property sit in two countries, do not require both probate courts to finish before a quorum exists. The delayed leaf should be signable by people who already hold their keys, plus a trustee who does not need a foreign court to open a drawer.

What to write down, and on what

The long-lived object is text a human can read in twenty years. Optical media is a good extra and a bad only. Store a USB DVD drive with any discs you do burn, because the reader is part of the backup, and assume even that drive may not have a working driver later. Text still wins.

For each key, four representations of one root:

- **Steel BIP39 words.** Fire, flood, and a decade. This is the canonical backup. Paper alone is not.
- **The passphrase, or an explicit record that there is none.** Never on the same plate as the words. A memorized-only passphrase dies with you. That is a theft feature and an inheritance bug. Keep it at a different site, with a sealed copy held by the trustee.

- **The output descriptor, with its checksum, in clear text.** This is the map. It replaces the shopping list of script type, derivation path, xpubs, and quorum. Multisig seeds without this map do not reconstruct the wallet. The descriptor is not a spending secret. It does reveal the policy and, once the wallet has been used, it points at the holdings. Store it widely: with every seed, in the trust binder, and on the watch-only node. Heirs fail from a missing map more often than from a missing clever cipher. For taproot, the full descriptor is required, not just the output key.
- **A watch-only Core wallet.dat, plus a one-page runbook.** Convenience for this decade. Encrypt any file that actually contains private keys. Do not encrypt the runbook. Yeti's instinct to put a README next to the key is correct. The failure mode of clever custody is a locked box nobody can interpret.

Also record a handful of receiving addresses and a rescan height, so a restore can be checked before a real spend. Words rebuild keys. They do not rebuild labels and history. The descriptor plus a rescan covers the part that matters. A wallet birthday of "I don't know, start at genesis" is acceptable and slow. A wrong birthday that skips the deposit block is how people decide the coins are gone.

The minimum record, if you want it as a checklist rather than a paragraph:

- The 12 or 24 words, on steel.
- The BIP39 passphrase, or the explicit statement that there is none. Stored apart from the words.
- The output descriptor with checksum. This covers script type, paths, cosigner xpubs, threshold, and any timelock or other Miniscript policy.
- Account index if it is not the default, and a note if anything is non-standard.
- A few previously used receiving addresses, to confirm the restore matched.
- A block height or date to rescan from.
- Where the other keys are, described well enough for a trustee, and not written onto the steel.
- Which software and which version successfully signed a test transaction.

Skip Shamir secret sharing as a substitute for the vault. Shamir recombines into one key in one room. Multisig never does. Shamir is reasonable only for splitting a passphrase, or for splitting one seed of a larger multisig across drawers.

Skip BIP-85 as the root of everything. One master compromise is a total compromise. It is fine for deriving a low-value child wallet. It is the wrong root for the deep vault.

The will should not contain seeds, passphrases, or street-level hiding places. Probate filings have a way of becoming readable. The will says the trustee has the Bitcoin instructions. The trustee holds the location map, the descriptor, and the delayed key. The trustee does not hold a live quorum.

The signer is a disposable tool

Build it so you can throw it away.

Everyday air gap

A stateless QR signer. SeedSigner or Krux on a board with no radio, or a Jade that does not store the seed. The seed lives on steel. You load it for the session, check the outputs on the device, sign, and power off. The device then holds nothing a thief can use. EntropyLab already speaks animated ur:crypto-psbt QR codes, so the unsigned transaction does not need a USB stick. QR is slower than a cable. That is the point. USB is a tunnel.

High-assurance air gap

A used laptop, ThinkPad-class, bought ordinarily. Unscrew the Wi-Fi card and leave it in a drawer. Software flight mode is not an air gap; the card is still in the machine, and the management engine is still there. Boot a verified live image every time, with no persistent disk. The online machine, which only has the watch-only descriptor, builds the PSBT. It crosses the gap as QR, or as a last resort a small SD card, not as a USB drive handed to a host controller. Sign in Bitcoin Core or on the stateless signer. Bring the signed PSBT back. Decode it on the online machine before broadcast.

Yeti rebuilds this environment from a live image on every signing day, then deletes the keys. That part is worth copying even if you do not copy the 3-of-7 disc design. Do not promote the old generation laptop into a daily online computer years later.

The check that matters

Three displays must agree before you sign: the coordinator, a second watch-only device that only has the descriptor, and the signer itself. Destination, amount, and fee. If any of them differ, do not sign. This is the actual job of a hardware screen. A clean Core machine does not fully replace it. Use both. Screens lie. A second independent decoder is cheap.

Never load two seeds onto one signer in one session. A compromised signer that sees a quorum has the vault.

After any major Bitcoin Core upgrade, round-trip a small test PSBT before a real one. Core 32 changed how multisig PSBTs are constructed. Coordinators and signers drift. A test spend is part of the setup, not a demonstration.

Inheritance that still works if everyone is difficult

Bitcoin cannot read a death certificate. Only two mechanisms can release coins you are no longer around to spend. A human who holds a missing key and agrees to use it. Or a timelock that matures because the coins stopped moving. Use both, on the family pile only.

- Your live quorum does not include the heir.
- A spouse can sit on the delayed path immediately, and on the live path only if you want them co-signing ordinary spends.
- The trustee holds one delayed key, sealed, released on death or incapacity under the trust deed. They also hold the map. They cannot spend today, alone or with one stolen key, until the timelock says so.
- Once, while everyone is alive and calm, do the embarrassing test. Restore one key from steel onto a blank signer. Sign a small PSBT. Have the spouse open the runbook and find the descriptor without you handing it over. An untested backup is a story.
- Name one Bitcoin-competent person who does not hold a live key, so a grieving family is not a lead for a “wallet support” caller. The runbook should say, in plain language, that nobody legitimate will ever email or call to validate the wallet.

Nunchuk’s on-chain decay is the same idea if you want a product to maintain the policy, with the BSMS export treated as the sovereign copy. Casa or Unchained is reasonable for a slice where you want a call center. Do not let their key be required for the deep vault, and assume they can see balances.

A one-page runbook beats a clever system. It should say what exists (two vaults, in rough terms, not a treasure map of amounts), the descriptor strings, the timelock in human language, who must cooperate, which software was tested, and the instruction to send a small transaction before moving the rest. It should not include the seeds.

Ideas outside the usual ladder

XOR the entropy sources

Dice rolls alone can be photographed. A memorized phrase alone is a brainwallet, and brainwallets get ground. Feed both into the calculator so neither source is sufficient, and write the combination rule into the trustee packet. The rule without the dice is useless. The dice without the rule is useless. Write the rule down. Do not leave it as a family legend.

A canary output

Leave one small UTXO on the family descriptor and watch it from the online node. If it moves, someone is spending that policy. Heirs can also see that the coins are still sitting still, which is the only liveness signal Bitcoin will give them. The canary is not a dead-man switch. It is an alarm.

Heartbeat is a consolidation, not a lifestyle

Once a year, spend the family-vault coins to themselves under the same policy. That resets the relative timelock. The deep vault is not on a timer and can sit for years. Put the reminder on a calendar you will actually see. A two-year delay means a missed year is annoying rather than fatal.

Keep the drive with the discs

If you keep a Yeti-style optical copy, box a cheap USB optical drive with the discs, and also print the descriptor and the runbook on paper in the same box. The disc may hold a wallet file and a long README that steel cannot hold. The paper is what you fall back to when the drive is a curiosity.

Do not leave an heir a FROST share as the plan

Threshold signatures (FROST) can split an heir key so that no single person ever holds a complete private key, and air-gapped signing firmware for that already exists on hobby hardware. It is not mature enough, or widely reviewed enough, to hold savings. Interactive signing is also a miserable ceremony to leave a family. Script-path multisig is slower, uglier on chain, and recoverable by people who are not in the same room. Prefer that.

Duress and inheritance fight each other

A decoy wallet and a passphrase wallet are useful against a wrench attack and dangerous against a spouse who tries one passphrase, finds a small balance, and stops looking. If you use a passphrase, the runbook must say that one exists, without sitting next to the steel. Pick the threat that is actually more real in your life and design for that one. Designing for both at full strength usually means the family gets nothing.

Skip MuSig2 for the family path

MuSig2 spends looking like a single signature, which is good for fees and privacy, and it wants the participants to interact during signing. That is the wrong ceremony for an heir, a trustee, and a laptop in a drawer. Use it someday for a live spending key if the tooling is boring by then. Do not use it as the inheritance leaf.

Separate the identities of the coins

A personal cold stack, a trust's stack, and operating-business or mining coins should not share a descriptor, a signer session, or a backup envelope. Mixing them creates one compromise that hits everything, and it creates a legal story you will not be able to untangle later. The trust's vault should have the trustee in the policy by design. The personal vault should not.

What not to build

- One hardware wallet, called “cold storage.”
- Seven keys generated in one Core session with no user entropy, if the goal is to survive a Coldcard-class bug. Yeti’s random-number bet may be fine. Dice makes the bet unnecessary.
- A single 3-of-7 with a decaying leaf on every coin. Maximum loss tolerance, maximum chance the family never spends it, and a timer on the serious money.
- Seeds in a password manager, a cloud drive, a photo library, or the text of the will.
- An heir who holds a live key now.
- Any plan whose only copy is a wallet.dat on a disc, or whose only copy is 24 words with no descriptor.
- Shamir as the vault.
- A memorized passphrase with no written copy anywhere.
- An inheritance design that only works if a specific company, app, or GitHub repository still exists.
- Loading a quorum of seeds onto one computer, even an air-gapped one, in a single sitting after the vault is funded.

The sentence to design around

Generate from entropy you supplied, in a separate ceremony per key, and check the result in a second program. Back the keys up as words on steel, and back the policy up as a descriptor in clear text. Sign on a stateless machine you can lose. Keep the serious money on a quorum you alone can meet, with no timer. Give the family a second, smaller policy that Bitcoin itself opens if you go quiet, with a trustee as a person rather than a Bitcoin company.

Once those jobs are separated, the arguments about gadgets get smaller. The hardware wallet, the Core laptop, the QR signer, and the archival disc are all replaceable views of the same authority. The authority is the entropy, the threshold, the map, and the rule for when someone else is allowed to use it.

Sources and further reading

Mr. Hodl, “Cold storage is not a device,” 3 October 2026. <https://x.com/MrHodl/status/2106514934570123438>

Yeti 2.0 procedure, FAQ, threat model, and start-here note. <https://github.com/bowlarbear/yeti-2.0>

EntropyLab, air-gapped key and wallet calculator. <https://github.com/OogaBoogaX/entropylab>

Team Ooga Booga. <https://oogabooga.rocks/>

Bitcoin Core multisig and offline-signing tutorials, in the Core repository under doc/.

Liana, Miniscript wallet with timelocked recovery paths. <https://github.com/wizardsardine/liana>

Wizardsardine, “The multi-vendor multisig standard,” on decaying quorums paired with vendor diversity.

Nunchuk, autonomous on-chain inheritance (Miniscript timelock and decaying quorum) and the separate off-chain flexible protocol.

Unchained and Casa, collaborative 2-of-3 custody. Recovery is possible without the company only if you actually hold a quorum and the wallet configuration.

Coldcard entropy incident, July–August 2026. Weak seeds from a firmware RNG failure; single-sig losses; multisig largely contained the theft. Fixed firmware does not heal old seeds.

This is a brainstorm, written to be argued with. It is not a personal setup procedure, not legal or tax advice, and not an instruction to move coins. The designs above have operational costs — annual consolidations, geographic key splits, a trustee who must be able to find a descriptor — and those costs are the security. A plan that is never restored from steel, never test-spent, and never shown to the person who would have to use it, has not been built yet.